

EN-304-617

Browsers

Deep Dive Session

With Two Dans

<https://labs.etsi.org/rep/stan4cra/en-304-617>



CRA Introduction

- **New Legislative Framework**
- **In Force since Dec 10, 2024**
- **In Application in Stages**
- **In Full application by Dec 11, 2027**

More?

I wrote a book about it:
Manufacturing European Compliance



Products, not services! The Market! What about Open Source?!!!

All products with digital elements that have an intended and foreseeable use that includes direct or indirect data connection to a device or network will have cybersecurity obligations imposed upon them.

Declaration of Conformity
Presentation of Mark
User Handbook (translated)
Technical Documentation
SBOM (top level)
Cybersecurity Risk Assessment
Evidence
Retention period



EU Standardisation Request

- (2) Harmonised standards play an important role in facilitating the assessment of conformity with those requirements. Products with digital elements which are in conformity with harmonised standards, which translate those essential requirements into detailed technical specifications, should therefore be presumed in conformity with the Cyber Resilience Act.

Harmonised Standards

- **Optional!!!**
- **Important I, II, Critical**
- **Modules A, B+C, H**
- **Presumption of Conformity**



Browser Standard



Structure

1. Scope
2. References
3. Definitions
4. Architecture, use cases
5. Requirements – **NORMATIVE**
6. Assessments – **NORMATIVE**



1. Scope is given to us

Commission Implementing Regulation (EU) 2025/2392 of 28 November 2025

2. Standalone and embedded browsers

Software products with digital elements that enable end users to access, render, and interact with web content and services hosted on servers that are connected to networks such as the Internet. They typically include a browser engine for interpreting and displaying content written in markup language (e.g. HTML), support for web protocols (e.g. HTTP, HTTPS), the ability to execute scripts and manage user inputs as well as storage of temporary or persistent data from websites (cookies).

This category includes but is not limited to standalone applications that fulfil the functions of browsers, embedded browsers intended for integration into another system or application as well as browsers with AI agent integration.

References

2.1 Normative references

Restricted to ISO, ITU, IEC

plus the European Standards Organizations ETSI, CEN, CENELEC

* EAA got an exception for WCAG



2.2 Informative references

Can be to anything, including lowly industry standards

Cannot form the basis for a normative requirement or assessment of conformity



Why: Legal documents require a solid basis



4.4.2 Use Cases for Browsers

UC-B8: Critical Infrastructure

- Description: Web interfaces for SCADA, energy grid, water treatment, transportation control, or emergency dispatch.
- Typical workflows: Administered access, scoped to individual user accounts.
- Typical environments: Secure control rooms, data centers, or field stations - physically access-controlled, often air-gapped or operating within segmented network.
- Security considerations: Certificate management; zero trust architecture; mTLS; RBAC; supply chain controls; immutable logging.
- Risk level: Critical
- Rationale: Successful attack could disrupt essential services, cause physical damage, or endanger human life.

Why: Risk analysis informed by impact

4.5 Product overview and architecture

Rendering Engine: Processes HTML, CSS, and JavaScript, and layout system that transforms

JavaScript Engine: Executes JavaScript code and manages web applications while maintaining security boundaries

Network Stack: Manages all network communication and other protocols. Implements connection pooling

Process Architecture: Modern browsers are composed of several separated processes, such as the browser process, plugin process, and rendering process, to prevent one process from affecting others.

Storage Subsystem: Manages various types of storage, such as cache storage, each with distinct security policies

Sandbox Model: Web content executes within a sandbox, which is enforced at multiple levels - process isolation, memory isolation, and network isolation

Permission System: Browsers mediate access to system resources through a permission system that requires explicit user consent

Content Security Boundaries: The Same-Origin Policy (SOP) ensures that content from one origin cannot access resources from another origin

Certificate and Trust Management: Browsers manage certificates and trust, including mechanisms for certificate pinning and revocation

Why: Identify relevant risks and mitigations

5.7 Core Component Security

5.7.1 System Resource Access

[SYS] The manufacturer shall implement secure boundaries between web content and system resources through Hardware Abstraction Layers and API mediation.

Capability: HAL implementation, PWA support, accessibility features, and local storage mechanisms

Threats:

- Sandbox escape attacks
- Unauthorised file system access
- Hardware fingerprinting
- Resource exhaustion attacks
- Accessibility feature abuse for screen reading



SYS-1 Requirements (Limited system access with strict permissions)

- **SYS-1-REQ-1:** Browser shall enforce process-level sandboxing → Assessment: SYS-REQ-1
- **SYS-1-REQ-2:** Browser shall isolate renderer processes → Assessment: SYS-REQ-2
- **SYS-1-REQ-3:** Browser shall isolate GPU process → Assessment: SYS-REQ-3
- **SYS-1-REQ-4:** Browser shall isolate network service → Assessment: SYS-REQ-4

Normative!

Browser requirement categories:

- Origin Isolation
- Extensions
- Encryption
- Logging and crash reporting
- Updates
- Protocol handlers
- System access and isolation
- Embedded browsers
- Remote Data Processing Systems
- Derived browsers

Normative!

6.7 System Resource Access Security Assessments

Assessment: SYS-REQ-3 (GPU process isolation)

Reference: SYS-REQ-3 - Browser shall isolate GPU rendering operations in a separate sandboxed process

Given: A conformant browser with SYS-1 or higher capability

Task: GPU processes execute untrusted shader code and interact with complex graphics drivers that have historically been sources of vulnerabilities. Without GPU process isolation, exploits targeting graphics drivers or shader compilers could escape to access the filesystem, network, or other process memory, bypassing renderer sandbox protections. Isolated GPU processes with command buffer validation and sandboxing contain GPU-related exploits while enabling graceful degradation through software rendering fallbacks.

Verification:

1. Launch browser and navigate to the browser's GPU information interface to verify GPU process information → Verify that software rendering fallback maintains process isolation

■ ■ ■

Pass Criteria: GPU process is isolated with distinct PID AND sandbox is enforced AND command validation occurs AND crashes are contained

Fail Criteria: No GPU process isolation OR sandbox not enforced OR commands not validated OR crashes cascade

Evidence: GPU process information screenshots, PID verification, sandbox status reports, command trace logs, shader compilation logs, graphics debugging tool outputs

Normative!

No clause is written in stone.

**All may be improved based on
industry expertise.**

What's next?

- **Outreach**
 - Improve engagement with browsers and security community
- **Changes based on feedback**
 - from European Commission on drafts
 - from enhanced outreach
- **Continue refining text**
 - “cross-verticals” sharing requirements (e.g., encryption) and structure

Timeline

- **March 31, 2026 (or preferably February 28):**
Full complete draft due
- **During the next several months:**
Several rounds of review (which you can participate in)
And resulting edits, and more review
- **October 30, 2026:**
 's deadline for adoption by ETSI
- **In the following months:**
Standard reviewed by EC for full approval
- **December 11, 2027:**
CRA takes full effect



Why: Give manufacturers time to prepare

Please, get involved!

- Review the draft and file issues:
<https://labs.etsi.org/rep/stand4cra/en-304-617>
 - Feel free to suggest text or other concrete things
- Join ETSI and participate in the committee
 - Free involvement for open source projects
- Email me for help getting started, to complain, etc.
 - dan@crabnebula.dev

Why: This will impact browsers



Cyber Resilience Act



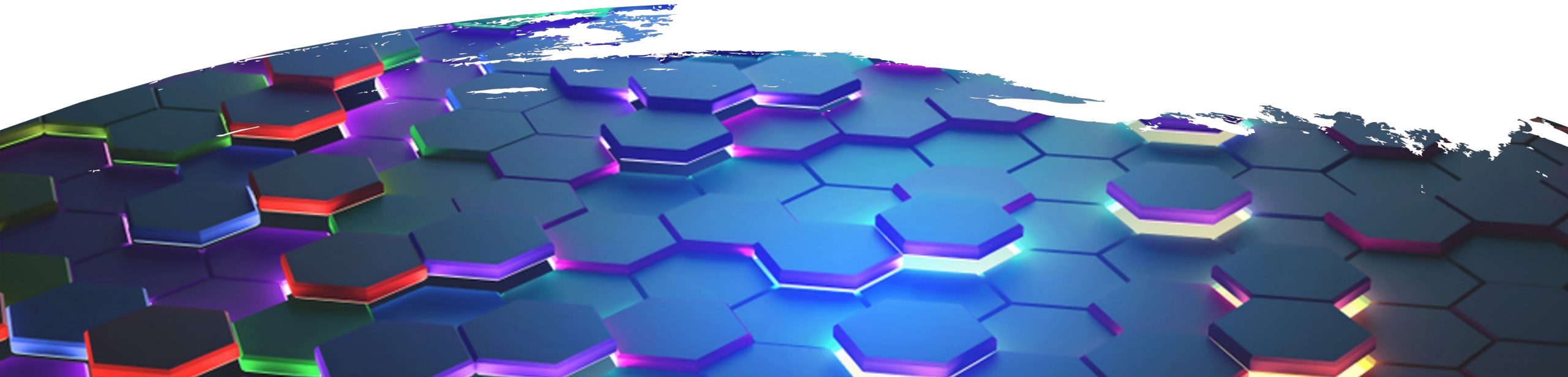
Browser Specification



File issues



Q&A





Thank you for your attention



Co-funded by
the European Union

Follow us on:   